

Project - Security Requirements

Aleksander Klap

08.06.2026

1 Security Requirements

<i>SR-01</i>	Network Segmentation
<i>SR-01.1</i>	The network shall be divided into the following security zones: - OT Field Zone (PLCs, HMIs) - OT Cell Zone (Festo Controllers, Robot Controller, Cameras, MQTT Device) - Industrial DMZ (OPC UA Proxy, MQTT Broker, Backup Server, Historian) - IT Zone (MES Server, COBOL Vision System)
<i>SR-01.2</i>	Each zone shall be implemented as a separate subnet/VLAN. Communication between zones shall only be permitted through firewall-controlled conduits.
<i>SR-01.3</i>	Direct communication from the IT Zone to the OT Field Zone shall be prohibited.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 5.1 – Restricted Data Flow - IEC 62443-1-1 – Zone and Conduit Model - NIS2 Article 21(2)(d)
<i>SR-02</i>	Firewall with protocol inspection
<i>SR-02.1</i>	The OT zones and IT zone shall be separated with the industrial firewall(s).
<i>SR-02.2</i>	Firewall rules shall enforce default-deny policy on all inter-zone traffic, with only explicitly whitelisted flows permitted: - OPC UA (TCP port 4840) from IDMZ OPC UA proxy to PLC's and Festo Controllers - MQTT (TCP port 8883 TLC) from MQTT device to MQTT broker in IDMZ
<i>Standards Reference</i>	- IEC 62443-3-3 SR 5.2 - IEC 62443-2-1 security management
<i>SR-03</i>	OPC UA Hardening
<i>SR-03.1</i>	All OPC UA servers shall operate in Security Mode: Sign&Encrypt with SecurityPolicy:Basic256Sha256.
<i>SR-03.2</i>	Each client (MES, COBOL) must authenticate with an application certificate. Anonymous and username/password authentication sessions shall be disabled.
<i>SR-03.3</i>	OPC/UA servers shall not be reachable from the nodes inside IT zone directly, all access routes shall be set through a dedicated OPC UA proxy in IDMZ
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 1.3, SR 3.1; OPC UA Part 2 (Security Model)

<i>SR-04</i>	MQTT Hardening
<i>SR-04.1</i>	The MQTT broker shall be hosted on a dedicated server inside IDMZ. All MQTT connections shall use TLS 1.2 or higher.
<i>SR-04.2</i>	Each MQTT publisher (MQTT CXV device) shall authenticate with a client certificate.
<i>SR-04.3</i>	Topic level ACLs must restrict publishers only to its own publish topics.
<i>SR-04.4</i>	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
<i>SR-05</i>	HTTP/Web Service Hardening
<i>SR-04.1</i>	All HTTP services on PLC's HMI's, Festo Controllers, and cameras shall be disabled unless strictly required for an operational functionality.
<i>SR-04.2</i>	If the Web Interface is required, it must be migrated to HTTPS (TLS 1.2+) with a device certificate, and access restricted by firewall to only specific source IP's of pooling systems.
<i>SR-04.3</i>	Topic level ACLs must restrict publishers only to its own publish topics.
<i>SR-04.4</i>	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
<i>SR-06</i>	Authentication and Least Privilege
<i>SR-06.1</i>	All interactive access (PLC programming, HMI configuration, robot controller configuration) to the OT devices shall require individual user authentication.
<i>SR-06.2</i>	Role separation shall be enforced: - Operator (monitor only) - Engineer (upload programs, change parameters) - Administrator (device configuration, user management)
<i>SR-06.3</i>	PLC Programming access (TIA Portal) shall be only possible from designated Engineering Workstation.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1–1.3; - IEC 62443-2-1 §4.3.3; - ISO/IEC 27001 A.9

<i>SR-07</i>	Secure Engineering Access
<i>SR-07.1</i>	A dedicated Engineering Workstation shall be physically or logically isolated from the IT Zone.
<i>SR-07.2</i>	The Engineering Workstation shall connect to PLC's only through industrial firewall via controlled conduit, with firewall rules permitting only TIA Portal protocols to the PLC's IP's.
<i>SR-08</i>	Logging and Monitoring
<i>SR-08.1</i>	All network devices (managed switches, routers, industrial firewalls, PLC's with switch modules) shall send logs to a centralized Syslog collector.
<i>SR-08.2</i>	The industrial firewalls shall log all denied traffic.
<i>SR-08.3</i>	OPC UA server shall log all sessions establishment and authentication failiures.
<i>SR-08.4</i>	The MQTT broker shall log all connect/disconnect events and authentication failiures.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 6.1, SR 6.2; - NIS2 Article 21(2)(f); - ISO/IEC 27001 A.12.4
<i>SR-09</i>	NTP/Time synchronization
<i>SR-09.1</i>	A single NTP server must be designated. All OT devices shall synchronize using this server.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Article 21(2)(c)
<i>SR-10</i>	NTP/Time synchronization
<i>SR-10.1</i>	All PLC programs, HMI and Controllers configurations must be backed up after every change to and dedicated backup storage.
<i>SR-10.2</i>	Backup must be stored offline.
<i>SR-10.3</i>	Recovery procedure shall be documented and tested at least once per half a year.
<i>SR-10.4</i>	MES database shall be backed up once a day.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; - ISO/IEC 27001 A.12.3; - NIS2 Article 21(2)(c)